

Prepared by: Sameh Gamil Mohammed

Assessment Type: Authorized Security Laboratory Assessment

Assessment Environment: Kali Linux localhost sandbox and OWASP Juice Shop local Docker deployment

Date: August 2026

Confidentiality: Training / Educational Use Only

Comprehensive Penetration Testing & Vulnerability Assessment

Executive Capstone Report

Document Control

Field	Value
Report Title	Comprehensive Penetration Testing & Vulnerability Assessment
Prepared By	Sameh Gamil Mohammed
Audience	Mentor / Executive Review Committee
Environment	Authorized local cybersecurity training laboratory
Primary Tools	Nmap, Wireshark, Docker, OWASP Juice Shop, Python
Assessment Scope	Network reconnaissance, service identification, web application security assessment,
Methodology	Evidence-driven laboratory testing and defensive remediation analysis
Classification	Educational / Authorized Testing Only

Important Evidence Statement

This report intentionally distinguishes confirmed observations from laboratory setup information and unverified hypotheses. Only findings supported by completed evidence are presented as confirmed. OWASP Juice Shop testing and cryptographic utility development are included as assessment workstreams; where proof-of-concept screenshots were not captured, the report does not falsely claim exploitation success.

Table of Contents

1. Executive Summary
2. Scope, Authorization and Rules of Engagement
3. Methodology and Assessment Approach
4. Asset Overview and Attack Surface
5. Executive Risk Matrix
6. Confirmed Technical Finding: Exposed HTTP Service
7. Web Application Assessment Workstream
8. OWASP Top 10 Mapping
9. Cryptography and Secure Authentication Review
10. CVSS 3.1 Scoring Methodology
11. Prioritized Remediation Roadmap
12. Developer Patch Guidelines
13. System Administrator Hardening Guidelines
14. Evidence Register
15. Limitations and Assumptions
16. Conclusion

1. Executive Summary

An authorized security assessment was conducted across a controlled local laboratory environment. The work combined network reconnaissance, service enumeration, web application vulnerability assessment preparation, and secure cryptographic implementation review. The objective was to demonstrate an end-to-end VAPT workflow suitable for structured technical and executive reporting.

The confirmed network assessment identified an intentionally exposed HTTP service on TCP/8080. Nmap service detection identified SimpleHTTPServer 0.6 running with Python 3.14.6. The target was localhost (127.0.0.1), and no third-party or production assets were scanned.

The web application assessment environment was successfully deployed using OWASP Juice Shop in Docker on local port 3000. The planned test areas included SQL Injection, Reflected and Stored XSS, and Broken Object Level Authorization / IDOR. However, this capstone report does not label those vulnerabilities as confirmed without completed screenshots or captured request/response evidence.

Overall risk should be interpreted in the context of an educational laboratory. The confirmed exposed service is expected because it was intentionally started. The principal value of the exercise is demonstrating discovery, validation, evidence handling, risk classification, and remediation planning.

2. Scope, Authorization and Rules of Engagement

In-scope assets:

- 127.0.0.1 on the assessor's Kali Linux system
- Intentionally started Python HTTP service on TCP/8080
- OWASP Juice Shop running locally in Docker on TCP/3000
- Self-developed cryptographic utility scripts

Out-of-scope assets:

- Public internet hosts and websites
- College, employer, cloud, or production infrastructure
- Third-party accounts and services
- Any network device not explicitly owned and authorized by the assessor

Rules of Engagement

- Testing was restricted to authorized local training targets.
- No destructive exploitation or persistence was performed.
- No credentials belonging to real users were targeted.
- Evidence was documented from terminal output and local tool results.
- Findings without proof were retained as assessment objectives rather than asserted vulnerabilities.

3. Methodology and Assessment Approach

The assessment followed a practical sequence aligned with common VAPT workflows:

Phase	Activity
1. Preparation	Define authorized targets and isolated local scope
2. Discovery	Confirm host availability and enumerate exposed ports
3. Enumeration	Identify services and versions using Nmap
4. Traffic Review	Prepare Wireshark capture on the loopback interface
5. Web Assessment	Deploy intentionally vulnerable Juice Shop locally
6. Risk Analysis	Map confirmed or potential issues to OWASP and CVSS concepts
7. Remediation	Develop prioritized defensive guidance
8. Reporting	Separate evidence-backed findings from incomplete test objectives

Tools used or prepared for the assessment included Nmap, Wireshark, Docker, OWASP Juice Shop, Python, and standard cryptographic libraries.

4. Asset Overview and Attack Surface

Asset	Role	Exposure	Status
127.0.0.1	Local assessment host	Loopback only	Authorized
TCP/8080	Python HTTP service	Localhost	Confirmed open
TCP/3000	OWASP Juice Shop	Localhost via Docker	Environment deployed
Cryptographic utilities	Security code demonstration	Local source code	Reviewed

The attack surface was intentionally minimal. The principal confirmed service was TCP/8080. The Juice Shop application was deployed specifically as a vulnerable training application, but vulnerability claims require individual evidence collection.

5. Executive Risk Matrix

Finding / Workstream	Likelihood	Impact	Priority	Evidence Status
F-01 Exposed HTTP service on TCP/80	Low	Low	Low	Confirmed
WA-01 SQL Injection testing	Unknown	Potentially High	Pending validation	Not confirmed
WA-02 Reflected/Stored XSS testing	Unknown	Potentially Medium-High	Pending validation	Not confirmed
WA-03 BOLA / IDOR testing	Unknown	Potentially High	Pending validation	Not confirmed
CR-01 Weak cryptographic implementation	Reduced by design controls	High if present	Preventive review	Code controls implemented

Executive interpretation: the only directly confirmed technical exposure in the captured evidence was the intentionally exposed local HTTP service. Other categories remain pending validation and should not be treated as confirmed production vulnerabilities.

6. Confirmed Technical Finding: Exposed HTTP Service

Finding ID: F-01

Asset: 127.0.0.1

Port: TCP/8080

Status: Confirmed Open

Service Fingerprint: SimpleHTTPServer 0.6 (Python 3.14.6)

Risk Context: Expected exposure in the intentionally configured local training environment

Evidence

```
sudo nmap -sS -p 8080 127.0.0.1
```

```
Nmap scan report for localhost (127.0.0.1)
Host is up
```

```
PORT      STATE SERVICE
8080/tcp  open  http-proxy
sudo nmap -sS -sV -O -p 8080 127.0.0.1
```

```
PORT      STATE SERVICE VERSION
8080/tcp  open  http      SimpleHTTPServer 0.6 (Python 3.14.6)
```

```
Warning: OSScan results may be unreliable
No exact OS matches for host (test conditions non-ideal).
```

Assessment

The service exposure was intentional and therefore does not automatically constitute a vulnerability. In a production context, any externally reachable service should have a documented business purpose, hardened configuration, patch lifecycle, logging, and network access restrictions.

7. Web Application Assessment Workstream

OWASP Juice Shop was deployed successfully in a local Docker environment. The service reported that the server was listening on port 3000. The assessment plan covered SQL Injection, XSS, and authorization flaws.

ID	Test Area	OWASP Theme	Current Evidence Status
WA-01	SQL Injection	Injection	Environment prepared; PoC evidence pending
WA-02	Reflected XSS	Injection / Client-side security	Environment prepared; PoC evidence pending
WA-03	Stored XSS	Injection / Client-side security	Environment prepared; PoC evidence pending
WA-04	BOLA / IDOR	Broken Access Control	Environment prepared; PoC evidence pending

Recommended completion step: capture reproducible screenshots and request/response evidence for each successful training challenge, then assign CVSS scores to the actual demonstrated impact rather than using generic maximum scores.

8. OWASP Category Mapping

Assessment Area	OWASP Category	Primary Defensive Control
SQL Injection	Injection	Parameterized queries, input validation
Reflected XSS	Injection / client-side handling	Context-aware output encoding
Stored XSS	Injection / client-side handling	Output encoding, sanitization, CSP
BOLA / IDOR	Broken Access Control	Server-side authorization per object
Weak password storage	Identification and Authentication Failures	bcrypt/Argon2 with appropriate work factor
Weak secret handling	Cryptographic Failures	Secret manager, rotation, access control

Mapping is used for remediation planning and does not imply that every category was successfully exploited during this assessment.

9. Cryptography and Secure Authentication Review

A separate cryptographic utility project was prepared to demonstrate secure primitives using established libraries rather than custom cryptographic implementations.

Control	Implementation
Symmetric encryption	AES-256-GCM with a 256-bit key and fresh random 96-bit nonce
Public-key cryptography	RSA 2048-bit key pair generation
Digital signatures	RSA-PSS with SHA-256 verification
Password storage	bcrypt with generated salt and configurable work factor
Message integrity	HMAC-SHA-256 with constant-time comparison
Key lifecycle	Documentation for protected storage and rotation

Key security principles: never hard-code production secrets, never commit private keys to Git, restrict private-key permissions, prefer managed secret storage in production, and support controlled rotation with versioned keys.

10. CVSS 3.1 Scoring Methodology

CVSS should be calculated from the demonstrated vulnerability characteristics, including attack vector, attack complexity, privileges required, user interaction, scope, confidentiality, integrity, and availability impacts.

For this capstone, a numeric CVSS score is not assigned to unconfirmed Juice Shop test objectives because doing so would imply evidence that has not been collected. The confirmed TCP/8080 exposure is an intentional service and is therefore treated as an informational/low contextual finding rather than automatically receiving a critical severity.

Severity Band	CVSS 3.1 Range	Operational Meaning
None	0.0	No security impact
Low	0.1–3.9	Limited impact; schedule remediation
Medium	4.0–6.9	Meaningful risk; remediate in planned cycle
High	7.0–8.9	Serious exposure; prioritize remediation
Critical	9.0–10.0	Immediate and significant risk

Once a vulnerability is demonstrated, its vector should be recorded explicitly and the score justified with evidence.

11. Prioritized Remediation Roadmap

Timeline	Priority Actions	Owner
0–24 hours	Remove unnecessary exposures; revoke suspected compromised credentials; isolate critical systems	Security Ops
1–7 days	Patch confirmed high-risk vulnerabilities; enforce server-side authentication; rotate affected credentials	Engineering + Security
7–30 days	Implement secure coding fixes; strengthen logging; add regression tests	Developers
30–90 days	Threat modeling, security automation, tabletop exercises, key security reviews	Security Leadership

Actual remediation priority must be updated after validating the pending web application test cases.

12. Developer Patch Guidelines

SQL Injection

```
# Parameterized query concept
db.query(
    "SELECT id FROM users WHERE email = ? AND password_hash = ?",
    [email, password_hash]
)
```

- Never concatenate untrusted input into SQL statements.
- Validate expected formats and types.
- Use least-privilege database accounts.
- Add security regression tests.

XSS

```
// Safe rendering
element.textContent = userControlledInput;

// Avoid assigning untrusted data directly to innerHTML.
```

- Use framework-native escaping.
- Apply context-aware output encoding.
- Sanitize only when HTML input is genuinely required.
- Deploy a restrictive Content Security Policy.

BOLA / IDOR

```
if (!resource || resource.ownerId !== authenticatedUser.id) {
    return forbidden();
}
```

- Authorize every object request server-side.
- Do not trust hidden UI controls.
- Test horizontal and vertical authorization boundaries.

13. System Administrator Hardening Guidelines

- Maintain an approved inventory of listening services and ports.
- Bind development services to localhost where remote access is unnecessary.
- Apply operating system and application patches through a documented lifecycle.
- Use host firewalls and network segmentation.
- Centralize security-relevant logs and monitor authentication failures.
- Restrict administrative interfaces with least privilege and MFA.
- Store secrets outside source code and rotate them through documented procedures.
- Back up critical configurations and periodically test restoration.
- Review exposed services after deployments and configuration changes.

Service Exposure Checklist

- Is the service required?
- Is it reachable only from required networks?
- Is authentication required?
- Is the software supported and patched?
- Are logs enabled?
- Is the service owner identified?

14. Evidence Register

Evidence ID	Description	Status
EV-01	Nmap TCP SYN scan against 127.0.0.1:8080	Captured
EV-02	Nmap service/version and OS detection output	Captured
EV-03	Wireshark loopback capture	Capture workflow prepared; final screens
EV-04	OWASP Juice Shop Docker startup	Environment deployed
EV-05	SQLi PoC screenshot	Pending
EV-06	Reflected XSS screenshot	Pending
EV-07	Stored XSS screenshot	Pending
EV-08	BOLA/IDOR screenshot	Pending
EV-09	Cryptographic utility source code	Created

The evidence register is intentionally explicit about missing artifacts to preserve report integrity.

15. Limitations and Assumptions

- The assessment was conducted in a local educational environment and does not represent a full enterprise penetration test.
- Only localhost services explicitly started for training were scanned.
- OS detection was inconclusive because scan conditions were non-ideal and insufficient port diversity was available.
- UDP scan results were not included in the captured evidence set.
- Wireshark packet screenshots were not included in the final evidence package at the time of report generation.
- Web vulnerability categories were prepared for testing, but successful exploitation is not asserted without screenshots or request/response proof.
- CVSS scoring should be finalized after vulnerability validation and impact analysis.

16. Conclusion

This capstone demonstrates the structure of an enterprise-oriented VAPT reporting workflow while preserving evidence integrity. The assessment successfully documented local service discovery and service fingerprinting, established a vulnerable web application training environment, and implemented secure cryptographic utility examples.

The primary confirmed observation was an intentionally exposed Python HTTP service on TCP/8080. Web application categories including SQL Injection, XSS, and Broken Access Control remain assessment objectives pending captured proof-of-concept evidence. This distinction is essential: an executive report should never convert planned testing into asserted findings.

The recommended next phase is to complete each authorized Juice Shop test case, capture reproducible evidence, calculate CVSS 3.1 vectors from actual demonstrated impact, and update this report before final mentor review.

Appendix A – Key Commands Used

```
# Local HTTP service  
python3 -m http.server 8080
```

```
# TCP SYN scan  
sudo nmap -sS -p 8080 127.0.0.1
```

```
# Service and OS detection  
sudo nmap -sS -sV -O -p 8080 127.0.0.1
```

```
# Local Juice Shop  
sudo docker run --rm -p 3000:3000 bkimminich/juice-shop
```

```
# Local application URL  
http://127.0.0.1:3000
```

Appendix B – Final Submission Checklist

- PDF reviewed for factual accuracy
- Executive summary completed
- Confirmed findings separated from pending tests
- CVSS vectors added for validated vulnerabilities
- OWASP mappings reviewed
- PoC screenshots embedded
- Remediation timelines approved
- GitHub repository README completed
- No secrets, credentials, or private keys committed